Phase 4: Reliable IT Infrastructure, Disaster Recovery & Enterprise SLA Policy

This document defines the production infrastructure topology, cybersecurity hardening matrix, backup & disaster recovery runbooks, and enterprise **Service Level Agreement (SLA)** for the Edukom Group proprietary LMS platform.

1. Production Infrastructure Architecture

2. Cybersecurity Hardening Matrix

Security Layer	Threat Vector	Technical Defense Implemented	Verified Config
Container Runtime	Privilege Escalation / Container Escape	Unprivileged non-root user `edukom` (UID/GID 10001)	
Network Isolation	Lateral Movement & Database Exposure	Complete network segmentation: `edukom_backend_net` is `internal: true` (zero host port bindings)	
Transport Layer	Man-in-the-Middle (MITM) & Downgrades	TLS 1.3 / 1.2 only, HSTS `max-age=31536000; includeSubDomains; preload`	
Brute Force & DoS	Credential Stuffing & Scraping	Nginx rate-limiting: `/account/Login` limited to 5r/m; `/video/drm-key/` limited to 15r/s	
Web Vulnerabilities	XSS, Clickjacking, MIME Sniffing	Content-Security-Policy (CSP), `X-Frame-Options: SAMEORIGIN`, `X-Content-Type-Options: nosniff`	&
Reconnaissance	Server Fingerprinting & CVE Targeting	`server_tokens off;`, generic HTTP 500 error pages, custom error pages	
Session Security	Session Hijacking & Theft	`SESSION_COOKIE_HTTPONLY=True`, `SESSION COOKIE SECURE=True`, `SESSION_COOKIE_AGE=86400`	

3. High-Availability Health Check Probes

The LMS platform exposes native health probes for container orchestrators (Docker, Kubernetes, AWS ALB, GCP Load Balancing):

3.1 Endpoint Specifications

- **Liveness Probe**: `GET /healthz/`
- **Readiness Probe**: `GET /readyz/`

3.2 Diagnostic Verification Suite

1. **Database Check**: Executes `SELECT 1` with latency timing. Unhealthy if unreachable or response time exceeds timeout.

2. **Cache Check**: Performs write/read/delete probe on Redis cache.
3. **Storage Headroom Check**: Inspects disk storage availability. Returns `503 Service Unavailable` with `critical_low_space` if free storage falls below 10%.

```
json
{
  "status": "healthy",
  "timestamp": "2026-10-16T19:01:45.036520+00:00",
  "total_latency_ms": 1.25,
  "components": {
    "database": {
      "status": "healthy",
      "latency_ms": 0.65
    },
    "cache": {
      "status": "healthy",
      "latency_ms": 0.35
    },
    "storage": {
      "status": "healthy",
      "free_gb": 110.2,
      "free_percent": 46.4
    }
  }
}
```

4. Disaster Recovery & Backup Runbooks

4.1 Target Recovery Metrics

- **RPO (Recovery Point Objective)**: **≤ 1 Hour** (Maximum allowable data loss window).
- **RTO (Recovery Time Objective)**: **≤ 2 Hours** (Maximum allowable time to restore full platform operations).

4.2 Automated Database Backup Runbook ()

- **Execution Frequency**: Automated daily at 02:00 WAT via cron, plus continuous WAL archiving.
- **Encryption**: OpenSSL AES-256-CBC encryption using PBKDF2 key derivation.
- **Integrity Guarantee**: SHA-256 checksum generated and stored adjacent to the backup archive.
- **Retention Schedule (Grandfather-Father-Son)**:

- Daily backups: Retained for 7 days.
- Weekly backups: Retained for 4 weeks.
- Monthly archives: Retained for 12 months.

4.3 Database Restoration Runbook ()

```
bash
# Execute disaster recovery restoration
./scripts/restore_database.sh /backups/postgres/edukom_backup_20261016_020000.dump.enc
"$BACKUP_ENCRYPTION_KEY"
```

Steps executed automatically:

1. Verifies SHA-256 checksum against cryptographic record.
2. Decrypts AES-256 ciphertext into temporary memory mount.
3. Gracefully terminates any existing database worker connections.
4. Executes `pg_restore --clean --if-exists` to rebuild tables, schemas, and indexes.
5. Performs post-restore health check verification via `/healthz/`.

5. Enterprise Service Level Agreement (SLA) & Incident Response Policy

5.1 Service Uptime Commitment

Edukom Group commits to providing a **99.9% Monthly Uptime** for all customer-facing educational services (WebRTC Classroom, Video DRM Library, Payment Portal).

$$\text{Allowable Downtime per Month} = 30 \times 24 \times 60 \times (1 - 0.999) = 43.8 \text{ minutes}$$

Allowable Downtime per Month = 30 × 24 × 60 × (1 − 0.999) = 43.8 minutes

Exclusions from Downtime Calculations:

1. Pre-notified scheduled maintenance windows (conducted Sundays between 02:00 and 04:00 WAT).
2. Upstream outages beyond Edukom's control (e.g. undersea fiber optic cable cuts affecting international routing).

5.2 Incident Severity Classification & Response SLA

Severity Level	Description & Trigger Examples	MTTA (Ack)	MTTR (Resolution)	Escalation Path
P1 - Critical	Platform total outage, WebRTC classroom connection failure during peak class hours, payment gateway failure preventing all student enrollment.	**≤ 15 Mins**	**≤ 1 Hour**	Lead Infrastructure Engineer → CTO → Executive Director
P2 - High	DRM video player degraded for a subset of courses, automated WhatsApp reminders delayed by > 15 minutes, tutor payroll calculation error affecting a batch.	**≤ 30 Mins**	**≤ 4 Hours**	Senior Backend Engineer → Lead Infrastructure Engineer
P3 - Medium	Minor portal UI alignment bug, student progress report PDF generation delay, non-urgent guardian notification preference sync issue.	**≤ 2 Hours**	**≤ 24 Hours**	Support Engineer → QA Lead
P4 - Low	Cosmetic enhancements, text or typo adjustments, feature requests for future quarterly releases.	**≤ 8 Hours**	**≤ 5 Days**	Product Backlog Grooming

5.3 Cybersecurity Incident Response Plan (CIRP) & NDPR Breach Compliance

Under the **Nigeria Data Protection Regulation (NDPR)** and international data protection standards:

1. **Detection & Triage (T+0 to T+1h)**: Security incident team isolates affected containers and blocks originating IPs at edge WAF.
2. **Containment & Eradication (T+1h to T+4h)**: Cryptographic keys, session tokens, and database credentials rotated immediately.
3. **Statutory Breach Notification (Within 72 Hours)**: If student, tutor, or financial PII is confirmed compromised, formal notification is submitted to the Nigeria Data Protection Commission (NDPC) and affected guardians within 72 hours of incident confirmation.

6. Enterprise DevSecOps, Monitoring & Zero-Downtime Operations

6.1 DevSecOps CI/CD Pipeline ()

Every pull request and merge to `main` undergoes automated security validation:

1. **Automated Unit Testing**: Runs all 52 tests spanning `payments`, `payroll`, `classroom`, `videolibrary`, `automations`, and `edukom.tests_health`.
2. **Dependency Vulnerability Scanning**: `pip-audit` checks all installed packages against OSV / PyPI known CVE advisories.
3. **Secret Leak Detection**: `gitleaks` scans commit history to prevent accidental commits of API keys or credentials.
4. **Container Vulnerability Auditing**: `trivy` scans the production Docker image for OS-level and application vulnerabilities.
5. **Django Security Deployment Verification**: Executes `manage.py check --deploy` to ensure all production security flags are met.

6.2 Automated SSL/TLS Lifecycle Management (`certbot`)

- Added in .
- Automatically provisions and renews Let's Encrypt certificates every 12 hours via webroot challenge.
- Sends an automatic `nginx -s reload` signal on renewal, guaranteeing HTTPS continuity without downtime.

6.3 Real-Time APM & Error Tracking with NDPR PII Masking (`sentry-sdk`)

- Integrated in .
- Custom `_scrub_sensitive_pii` event filter sanitizes credit card numbers, bank accounts, NUBAN digits, and passwords before exceptions leave the platform.
- Immediate operational notifications sent upon 500 errors or third-party API disruptions (Daily.co, Paystack).

6.4 Structured Forensic Security Audit Logging & Log Rotation

- Configured in with `RotatingFileHandler` (15MB file cap, 5 backup archives) at `/var/log/edukom/security.log`.
- Tracks unauthorized login attempts, failed webhook signatures, DRM key rejections, and payroll export events with ISO timestamps and client IP addresses.

6.5 Zero-Downtime Deployment & Automated Health Rollback ()

- Executes a pre-deployment database backup.
- Applies zero-downtime database migrations.
- Scales up new container workers before terminating old ones.

- Probes `/healthz/` to verify database and cache responsiveness. If the health probe fails, it **automatically rolls back** to the previous working image and database state.